

# IPMS VPS Security Hardening Report

**System:** tracker.enarxi.com / IPMS production VPS

**Report Date:** May 22, 2026

**Prepared For:** Hameed / Enarxi

## Executive Summary

The VPS was hardened during a live maintenance session with validation after each change. The server is now materially more secure than its initial state: SSH password login is disabled, SSH access is firewall-restricted to the current admin public IPv4, public database exposure rules were removed, Mosquitto was moved to localhost-only binding, Fail2Ban and auditd were enabled, nginx security headers and rate limiting were added, and the application runtime was moved off root into systemd services under the dedicated enarxi-staging user.

## Scope and Access Model

- SSH access is currently restricted by UFW to source IPv4 122.164.8.138 on port 22.
- This means access is limited to the current public IP, not strictly to one physical device. Any device exiting through that same public IP/NAT could connect if it has a valid SSH key.
- If the public IP changes, SSH access will stop until the allow rule is updated.
- IPv6 SSH is not allowed by UFW under the current ruleset.

## Baseline Findings Before Hardening

- Effective SSH still allowed password authentication because `/etc/ssh/sshd_config.d/50-cloud-init.conf` overrode the base `sshd_config`.
- UFW allowed SSH from anywhere and contained misleading public MySQL allow rules.
- Mosquitto was listening on `0.0.0.0:1883` with `allow_anonymous true`.
- The backend and BOM services were running as root under PM2.
- Fail2Ban was not installed.
- Audit logging was not active.
- nginx exposed version details and lacked HSTS, CSP, Referrer-Policy, Permissions-Policy, and API rate limiting.

## Changes Applied on the VPS

### SSH hardening

- Created /etc/ssh/sshd\_config.d/99-hardening.conf with MaxAuthTries 3, ClientAliveInterval 300, ClientAliveCountMax 2, X11Forwarding no, and AllowAgentForwarding no.
- Replaced the cloud-init override so /etc/ssh/sshd\_config.d/50-cloud-init.conf now enforces PasswordAuthentication no.
- Validated SSH configuration with sshd -t and reloaded ssh safely without breaking the active session.

## Firewall hardening

- Restricted SSH to 122.164.8.138 only.
- Removed broad allow rules for 22/tcp, 3306, 4050/tcp, and 3006.
- Kept public web access on 80 and 443 only, with default incoming policy deny.

## Defensive controls

- Installed and enabled Fail2Ban with an active sshd jail.
- Installed and enabled auditd for host audit logging.

## MQTT hardening

- Changed Mosquitto to listener 1883 127.0.0.1.
- Disabled anonymous access with allow\_anonymous false.
- Restarted the Mosquitto service and verified localhost-only binding.

## nginx hardening

- Enabled server\_tokens off.
- Tightened global TLS protocols to TLSv1.2 and TLSv1.3.
- Added HSTS, CSP, Referrer-Policy, Permissions-Policy, and always-on frame/content-type headers to the tracker.enarxi.com vhost.
- Added API rate limiting and hid X-Powered-By at the proxy edge.
- Validated nginx configuration and reloaded successfully.

## Application least privilege cutover

- Copied the deployment from /root/IPMS-Enarxi to /home/enarxi-staging/IPMS-Enarxi.
- Created systemd units: ipms-backend.service and ipms-preview-bom.service.
- Moved runtime ownership from root/PM2 to enarxi-staging/systemd.
- Stopped and killed the root PM2 runtime after successful cutover.

## Configuration backup

- Saved pre-change backups under /root/security-hardening-20260522-090130.

## Verified Live State After Hardening

- systemctl reports active: ipms-backend, ipms-preview-bom, fail2ban, auditd, nginx, mosquitto, and ssh.
- sshd -T reports passwordauthentication no.
- UFW now allows 22/tcp only from 122.164.8.138 and denies 3306 publicly.
- Listening sockets show 127.0.0.1-only services for 1883, 3306, 5000, 6379, and 8100.
- Public listeners are limited to 80, 443, and 22.
- https://tracker.enarxi.com returns 200 OK with hardened response headers.
- The backend and BOM services remained reachable after the cutover.

## Current Security Posture Snapshot

| Control Area           | Current State                                        | Status   |
|------------------------|------------------------------------------------------|----------|
| SSH password login     | Disabled in effective config                         | Improved |
| SSH source restriction | Allowed only from 122.164.8.138                      | Improved |
| Fail2Ban               | Installed and active for sshd                        | Improved |
| Host audit logging     | auditd installed and active                          | Improved |
| MQTT exposure          | Bound to 127.0.0.1 only                              | Improved |
| Database exposure      | MySQL bound to localhost; public allow rules removed | Improved |
| Web headers            | HSTS/CSP/Referrer-Policy/Permissions-Policy present  | Improved |
| App runtime privilege  | Runs as enarxi-staging via systemd                   | Improved |
| Kernel patch level     | Newer kernel installed but reboot pending            | Open     |

## Open Items and Recommended Next Actions

- 1 Reboot the VPS during a maintenance window to load the pending kernel upgrade from 5.15.0-173-generic to 5.15.0-179-generic.
- 2 Rotate production secrets stored in .env, including MongoDB credentials, JWT/AUTH secrets, Microsoft Entra secret, and vendor credentials.
- 3 Review and remove the legacy nginx vhost using server\_name your\_domain if it is not required.
- 4 Consider replacing the single-IP SSH rule with VPN or bastion access if the admin public IP changes frequently.

- 5 Consider adding a documented backup-restore test and periodic patch/restart schedule.

## Important Note on SSH Access

**Answer to the access question:** SSH is restricted to your current public IP, not to a single hardware device identity. If only your PC uses that internet connection, then effectively yes. If another device shares the same public IP and has the right SSH key, it could also connect.

## Report Integrity

- This report reflects the verified server state observed during the hardening session on May 22, 2026.
- Configuration changes were validated live through service status checks, socket inspection, firewall inspection, and HTTP header verification.